



By Nitesh Singh

Job Ready Free Live Training To Become A

SOC

Analyst L1 For Free

Defronix Cyber Security → <https://defronix.com>



A Workbook is an interactive, canvas-based report. It pulls data from various logs and transforms raw text into charts, maps, and grids.

Key Features:

- **Real-time Monitoring:** Unlike a static PDF report, Workbooks update as new logs fly in.
- **Interactivity:** You can click a "Failed Login" spike on a bar chart, and the Workbook can automatically filter the rest of the page to show only those specific events.
- **Consolidation:** You can combine data from multiple sources (e.g., Firewall logs, Office 365, and Endpoint data) into a single "Single Pane of Glass."

Use Cases in the SOC:

- **Incident Overview:** A dashboard showing how many "High" severity alerts are open and who is assigned to them.
- **Threat Hunting:** Visualizing patterns in network traffic to spot beaconing behavior.
- **Health Monitoring:** Checking if all your servers are successfully sending logs to your SIEM.

SOC Lookups: The Enrichment Tool



A Lookup (often called a **Watchlist** in Sentinel) is essentially a custom table of data that you upload to your security platform to provide context that isn't found in standard logs.

Why do we need them?

Raw logs are often "thin." A log might tell you that IP **192.168.1.5** accessed a file, but it won't tell you that this IP belongs to the **CEO's laptop** or a **high-value server**. A Lookup bridges that gap.

Common Types of Lookups:

Type	Description	Example Data
Asset Inventory	Maps IPs to specific hardware or owners.	10.0.0.5 = HR_Database_Server
Threat Intel	A list of known malicious IPs or file hashes.	8.8.8.8 = Known_Malware_Source
VIP List	Tracks high-profile users (Executives/Admins).	jdoe@company.com = CFO
Terminated Users	A list of employees who recently left.	Helps spot "ghost" account logins.



How Lookup works in a Query:

When a SOC analyst writes a query (like KQL), they use the Lookup to filter or "join" data.

Logic: *Show me all logins where the Username is found in the "Terminated_Users" Lookup table.*

How They Work Together

Imagine you are investigating a suspicious login:

1. **The Lookup** tells the system that the user is a "VIP" (the CFO).
2. The SIEM triggers an alert because the CFO is logging in from an unusual country.
3. **The Workbook** displays this alert on a global map, highlighted in red, allowing the SOC Manager to see the geographic anomaly instantly.

Assets: The "What"



An asset is any physical or virtual resource that stores, processes, or transmits data. In a SOC, we track assets to understand the "blast radius" of an attack.

Categories of Assets:

- **Endpoints:** Laptops, workstations, and mobile devices used by employees.
- **Infrastructure:** Servers (on-prem or cloud), virtual machines, and containers.
- **Network Devices:** Routers, switches, firewalls, and load balancers.
- **IoT/OT:** Smart cameras, printers, or industrial control systems (PLCs).

Asset Context (Metadata):

Knowing a device exists isn't enough. A SOC analyst needs to know:

- **Criticality:** Is this a test machine or the production database?
- **Ownership:** Who is the primary user or the system admin?
- **Patch Status:** Is it running an outdated OS with known vulnerabilities?

Identities: The "Who"



An identity is a digital representation of an entity that can perform actions. It is no longer just "a person"; it is anything that has a set of permissions.

Types of Identities:

- **User Identities:** Human employees, contractors, or guests.
- **Privileged Identities:** Admin accounts (Domain Admins, Global Admins) that have the "keys to the kingdom."
- **Service Principals / Non-Human Identities:** Accounts used by applications or scripts to talk to each other (e.g., a backup script that needs access to a database).
- **Managed Identities:** Identities automatically managed by cloud providers (like Azure/AWS) for resource-to-resource communication.

The Identity Perimeter:

In modern security, we say "**Identity is the new perimeter.**" Since people work from home and use cloud apps, the physical office wall doesn't matter anymore. Security now depends on verifying the identity via **MFA** (Multi-Factor Authentication) and **Conditional Access**.

Identities: The "Who"



Comparison Table

Feature	Assets	Identities
Focus	Hardware, Software, & Infrastructure	Users, Groups, & Service Accounts
Goal	Vulnerability management & Patching	Access control & Behavior monitoring
Risk	Is the device compromised or unpatched?	Is the account stolen or misused?
Security Tool	EDR (Endpoint Detection & Response)	IAM (Identity & Access Management)



In a SOC, **Metrics** are the heartbeat of the operation. They tell you if your team is a well-oiled machine or if you're drowning in noise. While **Objectives** define *what* you want to achieve (e.g., "Reduce the risk of data breaches"), **Metrics** are the *quantifiable data points* used to measure success.

We generally categorize SOC metrics into three buckets:
Operational, **Efficiency**, and **Strategic**.

Core Operational Metrics (The "Big Three")

If you only track three things, track these. They measure how fast your team reacts.

- **MTTA (Mean Time to Acknowledge):**
 - **What it is:** The average time it takes from when an alert fires to when an analyst assigns it to themselves and starts looking at it.
 - **Why it matters:** High MTTA means you have too many alerts (Alert Fatigue) or not enough staff.
- **MTTR (Mean Time to Respond/Remediate):**
 - **What it is:** The average time it takes to "close" an incident (neutralizing the threat).
 - **Why it matters:** This is the most critical metric for the business. The longer a hacker is in the system (**Dwell Time**), the more damage they do.



MTTD: Mean Time to Detect

MTTD is the measure of how long a threat exists in your environment before your security tools (SIEM, EDR, IDS) actually trigger an alert.

The Goal: The lower the MTTD, the better.

Why it's tricky: You often don't know when the "Actual Incident" started until the investigation is over. For example, if a hacker entered the network on Monday but the SIEM didn't alert until Thursday, your MTTD for that incident is **3 days**.

How to improve MTTD:

- **Better Log Coverage:** You can't detect what you can't see.
- **Advanced Analytics:** Moving from simple "If/Then" rules to **ML (Machine Learning)** that spots anomalies (like a user logging in from a new country).
- **Threat Intel:** Using **Lookups** to automatically flag known "bad" IPs the moment they touch your network.



Efficiency & Quality Metrics

These metrics help you understand if your tools and processes are actually working.

- **False Positive Rate:**
 - The percentage of alerts that turned out to be "noise" (benign activity).
 - *Goal:* Keep this low. If 90% of alerts are false positives, your analysts will stop paying attention.
- **True Positive Rate:**
 - The percentage of alerts that were actual security incidents. This validates that your detection rules are "tuned" correctly.
- **Alert Volume vs. Incident Volume:**
 - Shows the ratio of raw "pings" to actual "problems." If you have 10,000 alerts but only 2 incidents, your SIEM needs better filtering.



Strategic & Risk Metrics

These are the metrics you show to the "C-Suite" (CISO/CEO) to justify the SOC budget.

- **Dwell Time:**
 - The time between the initial infection and when the SOC finally detected it.
 - $\text{Dwell Time} = \text{Detection Time} - \text{Infection Time}$
- **Coverage Mapping (MITRE ATT&CK):**
 - A percentage showing how much of the "Attacker Playbook" you can actually see. (e.g., "We have 80% coverage for Ransomware techniques").
- **SLA (Service Level Agreement) Compliance:**
 - The percentage of "Critical" incidents handled within the promised timeframe (e.g., "95% of Critical alerts acknowledged within 15 minutes").



Metric Breakdown

Metric	Category	High Value = ?	Low Value = ?
MTTA	Speed	Bad: Understaffed / Alert fatigue	Good: Responsive team
MTTR	Impact	Bad: Complex/Slow processes	Good: Effective automation
False Positive %	Tuning	Bad: "Crying Wolf" / Bad rules	Good: High-fidelity alerts
Dwell Time	Visibility	Bad: "Silent" breach occurring	Good: Rapid detection



The "Why" Behind the Metrics

Metrics shouldn't just be numbers on a slide; they should drive **Action**:

1. **If MTTA is high:** Buy an automation tool (SOAR) or hire a Tier 1 analyst.
2. **If False Positives are high:** Spend a week "tuning" your KQL queries and Lookups.
3. **If MTTR is high:** Build better **Workbooks** so analysts have all the data in one place and don't have to hunt for it.

Pro-Tip: Avoid "Vanity Metrics." Tracking "Total Alerts Blocked" looks impressive (e.g., "We blocked 1 million hits!"), but most of those are just random internet scans that don't actually pose a risk. Focus on the metrics that prove your team is *fast* and *accurate*.